

Non-Security Considerations in Security Decisions

Workshop on Economics and Information Security
29–30 May 2003

Security is Always a Trade-Off



- You can have as much security as you want
 - What are you willing to give up to get it?
- Security always involves trade-offs
 - If no airplanes flew, 9/11 couldn't have happened
 - Gated communities offer more security but less privacy
- We make decisions every day about these trade-offs
- To do it thoughtfully, we must understand:
 - How security works
 - The threats and risks
 - The costs

Is the Trade-Off Worth It?

- When faced with a security countermeasure, you have to figure out two different things:
 - Is the security countermeasure effective in mitigating your personal risk?
 - Are the problems and trade-offs caused by the security countermeasure worth the additional security?
- You are constantly making that decision
- Sometimes the decision is made for you by others
- I want to formalize that decision process

3

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

Five Step Evaluation Process

- Step 1: What assets are you trying to protect?
- Step 2: What are the risks to those assets?
- Step 3: How well does the security solution mitigate those risks?
- Step 4: What other risks does the security solution cause?
- Step 5: What costs and trade-offs does the security solution impose?
- Finally: Is the trade-off worth it?

4

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

Why is Security So Rarely About Security?



- People rarely perform this decision
- People succumb to fear and uncertainty
- People believe in false promises of security
- People do things counter to their own security
- People say one thing and do another

5

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

Security and Agenda



- Every security decision affects multiple players, and the party who gets to make the decision will make one that's beneficial to him
- Every player has his own unique perspective, his own trade-offs, and his own risk analysis
- This drives everything about security
- You have to evaluate security opinions based on the positions of the players
- Often security decisions are made for non-security reasons
- The major security issues have nothing to do with security technology

6

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

What's Going on?



These graphics are an attempt at an explanation

Maybe someone with more economics training than myself can help me put an actual model together

7

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

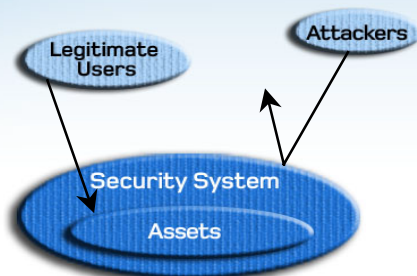
A Security System Protects Assets



8

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

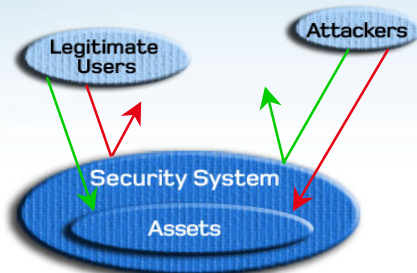
Both Legitimate Users and Attackers Interact with the System



9

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

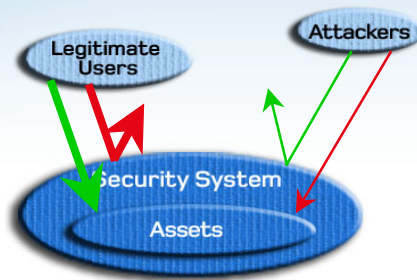
The Security Can Fail in Two Ways



10

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

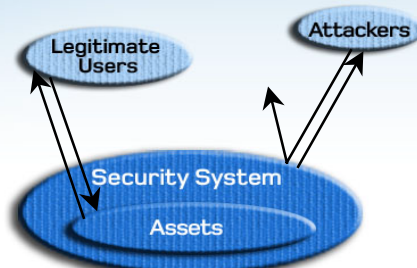
There are More Legitimate Users than Attackers



11

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

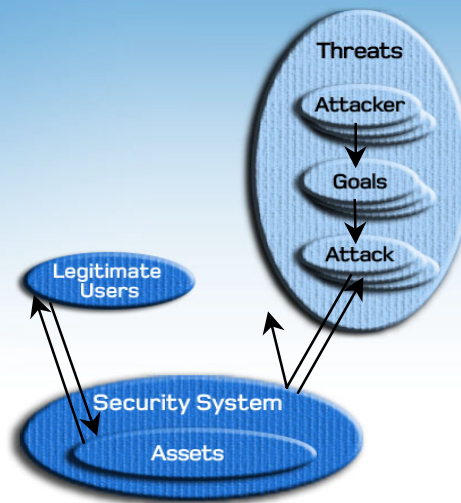
There is a Feedback Mechanism



12

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

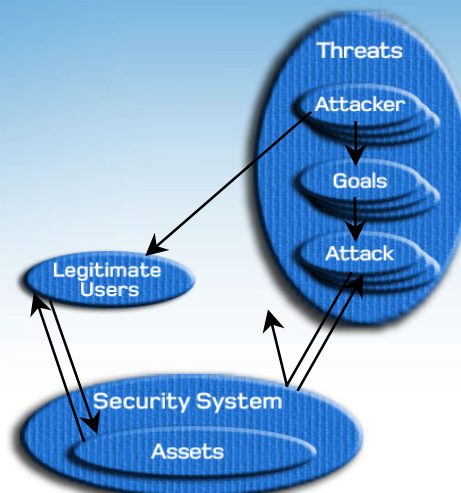
Threats are Complicated



13

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

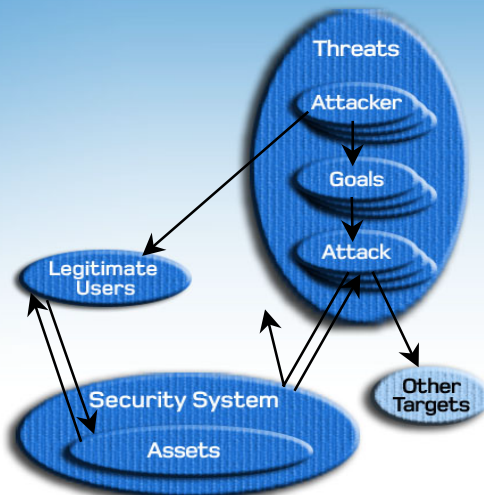
Attackers Can Be Legitimate Users



14

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

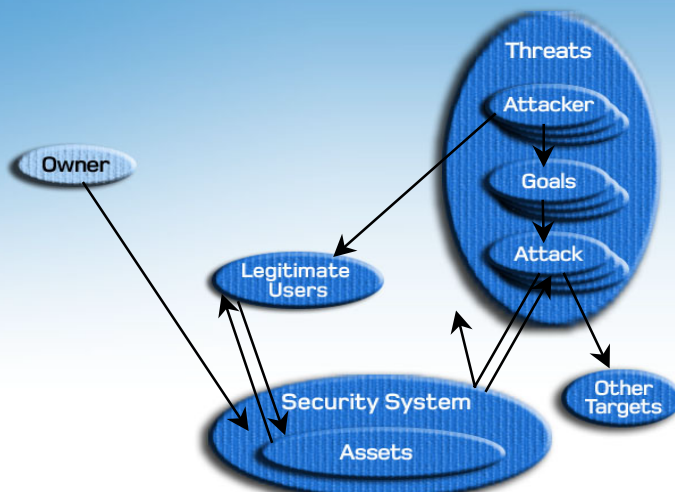
And One Outcome of Defense is Attack Diversion



15

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

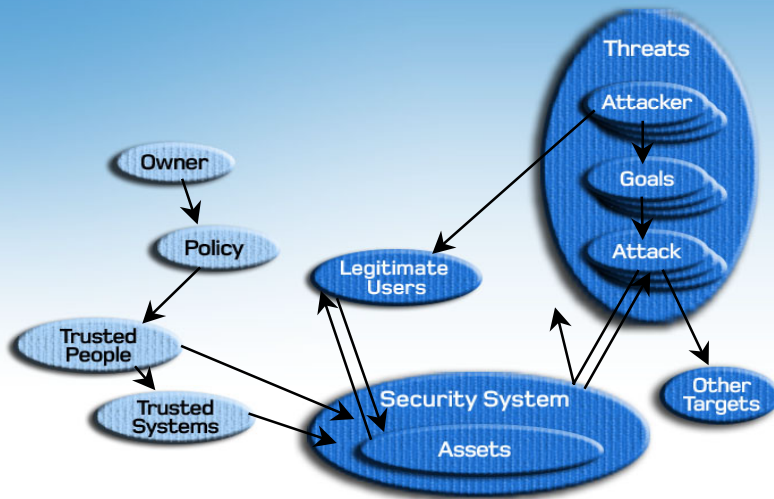
Asset Owner Controls Security System...



16

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

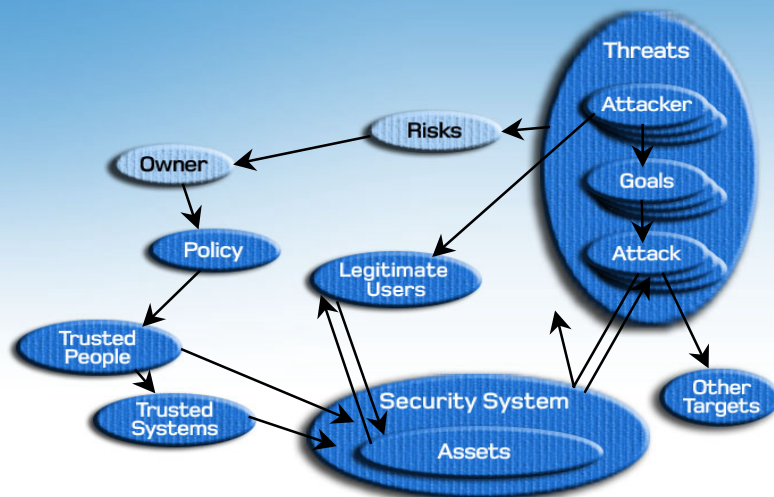
...but Not Directly



17

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

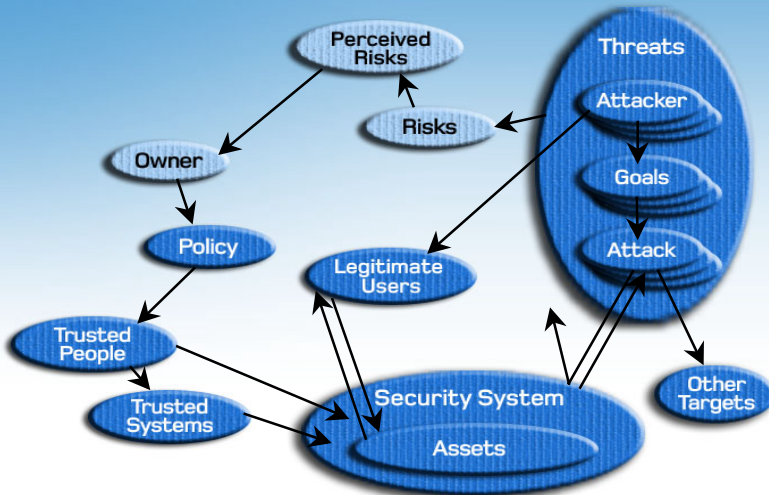
Asset Owner is Affected by Risks...



18

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

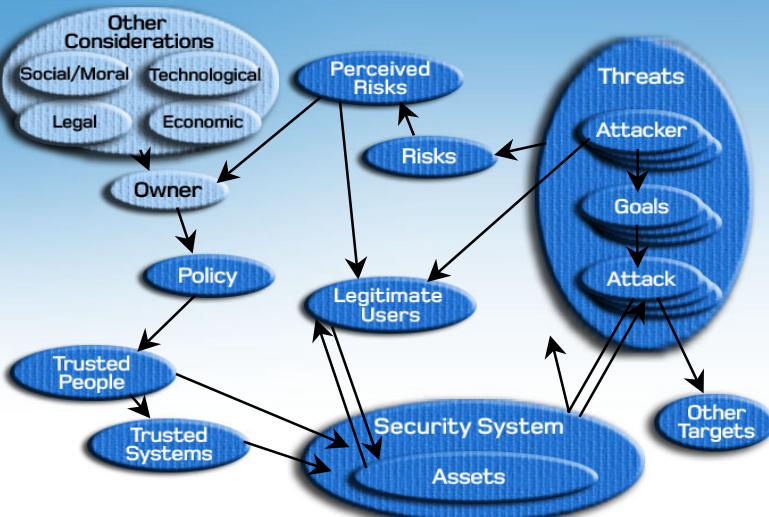
...but Not Directly



19

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

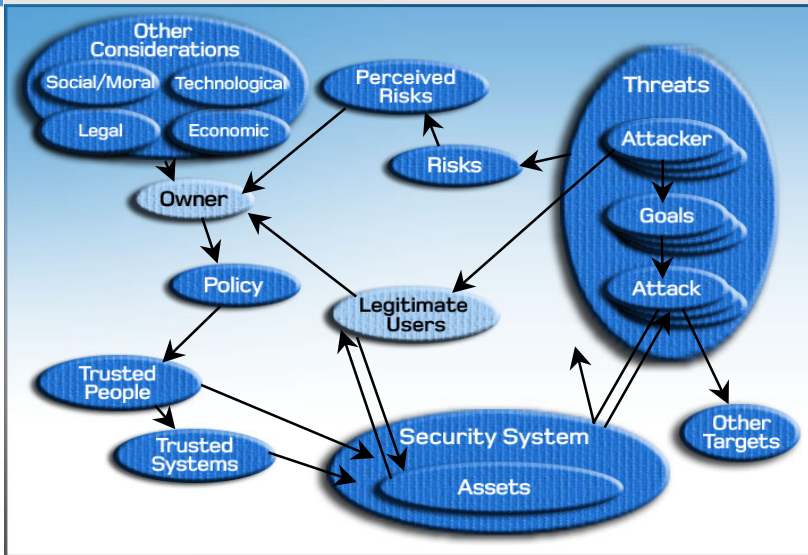
Asset Owner is Affected by Other Considerations



20

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

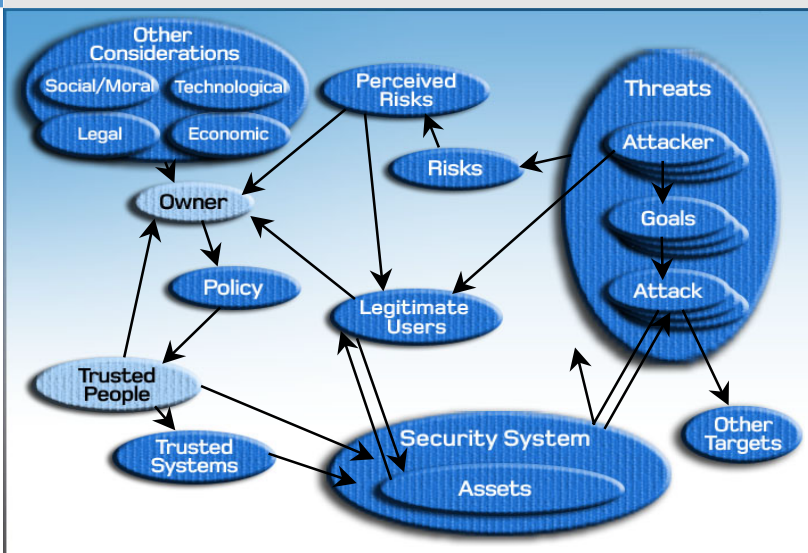
Asset Owner is Affected by Legitimate Users



21

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

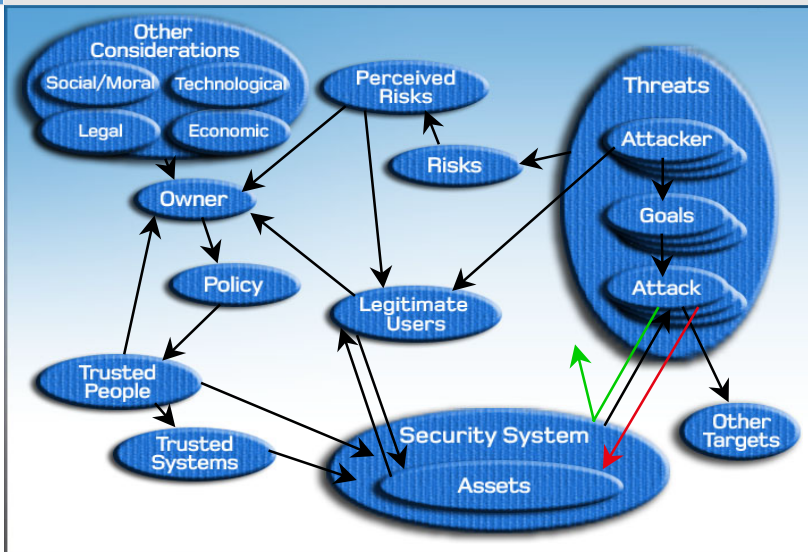
Asset Owner is Affected by Trusted People



22

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

The Effectiveness of the Security System is a Minor Consideration



23

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.

Examples

- Detecting counterfeit money
- KAL 007
- Salesclerks and credit card verification
- Counterterrorism in the wake of 9/11
- Tylenol poisonings
- Banning things on airplanes
- Home building inspectors
- Mercenaries
- DVD region encoding
- Government regulatory bodies
- Banks' verification of signatures on checks
- "Your purchase free if you don't get a receipt"
- ATM cards (in the U.S. vs. in the U.K.)
- Making employees liable for fraud
- Airport screeners (airline-paid vs. TSA)

24

INTELLIGENT ALERT. INSTANT RESPONSE. IMMEDIATE DEFENSE.